

ISYS90090 · CYBERSECURITY MANAGEMENT

Week 5

Defence in Depth

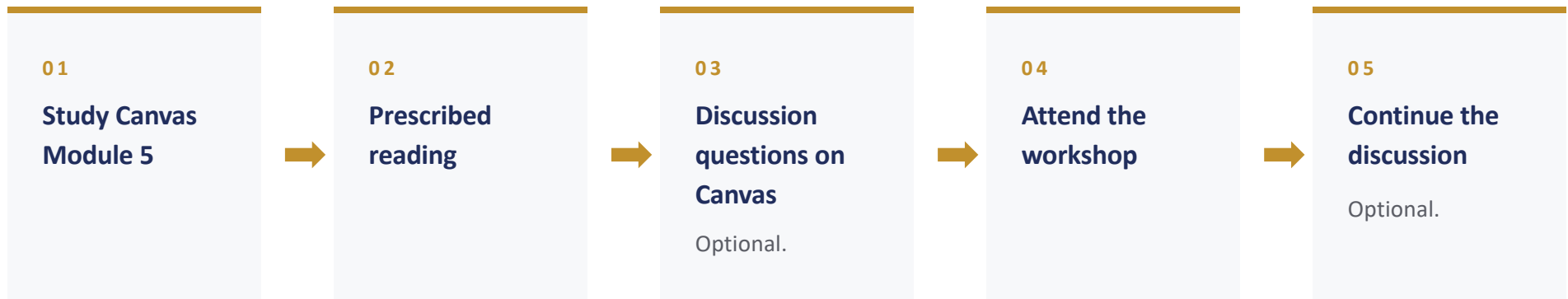
Layered defence, and the technologies that build each layer.

ATIF AHMAD · UNIVERSITY OF MELBOURNE



THIS WEEK

This Week in Cybersecurity Management



Chapters 8 and 9 — “Security Technology: Access Controls, Firewalls and VPNs” and “Security Technology: Intrusion Detection and Prevention Systems”, pp. 295 to 283.

PREScribed READING · WHITMAN & MATTORD

IN THE ROOM

This Week's Workshop

Part A runs first. Parts B and C follow if time allows.

01

Oral presentations

Assignment 2 group presentations.

02

Q&A session

On this week's content. If time.

03

Teaching case

Horizon, Scenes 10 and 11. If time.

Intended Learning Objectives

01

Defence in depth

Explore the concept of 'defence-in-depth', specifically how a layered defence strategy based on the castle model provides security to information assets.

02

Technological controls

Identify a range of technological controls, their respective advantages and disadvantages, and the role they play in 'defence-in-depth'.

RECALL

The Triplet Model

Each combination of asset, threat and vulnerability is a distinct and separate risk.



CASTLE TRAPS & DEFENSES

AWESOME FEATURES TO WITHSTAND ANNIHILATION

TROU DE LOUP

Pit with sharp stake — defensive obstacle or covered to serve as booby trap

BENT ENTRANCE

Narrow gateway with sharp turn—designed to slow attackers

MURDER HOLE

Hole in ceiling for rocks, scalding water or tar to be thrown on attackers

ARROWSLITS

Slit in wall for archers, providing protection from attackers while they fired

TALUS

Sloped base of a defense wall—kept invaders far from the wall

SPIRAL STAIRCASE

Usually spiraled clockwise going up—put right-handed attackers at a disadvantage

MOAT

Deep trough, often full of water, served as a first line of defense

SOURCES: CastlesAndManorHouses.com, The History of Castles: Fortifications Around the World by Christopher Gravett

DOOMSDAY CASTLE

#DOOMSDAYCASTLE

TUESDAYS 10P



THE PARADIGM

Defence in Depth

Layers of space between the threat agent and the asset. The outermost layer is the least safe; the innermost is the safest. Every obstacle delays the attacker.

THE DIGITAL EQUIVALENT

Defense in Depth

Layered Security like a Castle

ARROWSLITS

Narrow vertical slits in walls and towers for ranged defense.

MURDER HOLE

Openings in the ceiling of the gate passage to drop projectiles on attackers below.

MOAT

Wide water barrier that impedes and channels attackers.

TALUS

Sloped stone base that deflects scaling ladders and undermining attempts.

BARBICAN AND BENT ENTRANCE

Outwork and angled passage force attackers to turn 90 degrees before the gate.

VAULT

Strongroom at the base of the keep protects crown jewels and critical assets.

CONCEALED SPIKED PIT (TROU DE LOUP) — hidden trap beyond the cleared approach.

A DETECTION & RESPONSE
Watchtowers, sentries, and signal beacons at every layer

B DECEPTION & TRAPS
Concealed pits and false passages at every layer

LAYERS AND FUNCTIONS

1

MOAT & TERRAIN

Physical and environmental controls

2

OUTER WALL & GATEHOUSE

Perimeter defenses; firewall

3

OUTER BAILEY

General-access internal zone; user and device network

4

INNER BAILEY

Restricted zone; privileged systems, segmented

5

KEEP

High-value systems and applications

A

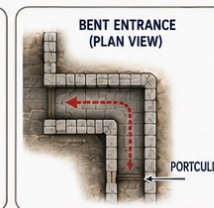
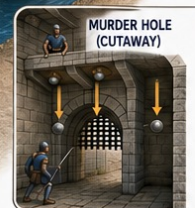
DETECTION & RESPONSE

Watchtowers, sentries, and signal beacons at every layer

B

DECEPTION & TRAPS

Concealed pits and false passages at every layer



MULTIPLE BARRIERS

An attacker must defeat every layer, not one.



MUTUAL SUPPORT

Inner layers cover and reinforce outer layers.



VISIBILITY & RESPONSE

Detection and response operate across all layers, not at one perimeter.



GARRISON

Controls without people to operate them are decoration.

First Line of Defence: Separate

The perimeter — firewalls and VPNs.

A device that selectively discriminates against information flowing into or out of the organization. In the context of physical security, a firewall is a wall that limits the spread of damage should a fire break out in an office.

WHITMAN & MATTORD, P. 587, 2012

Why do we need firewalls?

- Firewalls act as barriers between an organisation's (trusted) information infrastructure and the (untrusted) Internet.
- Firewalls regulate network traffic from one logical zone to another.
- For firewalls to be effective, traffic must be routed through them — not around them.

What a Firewall Actually Does

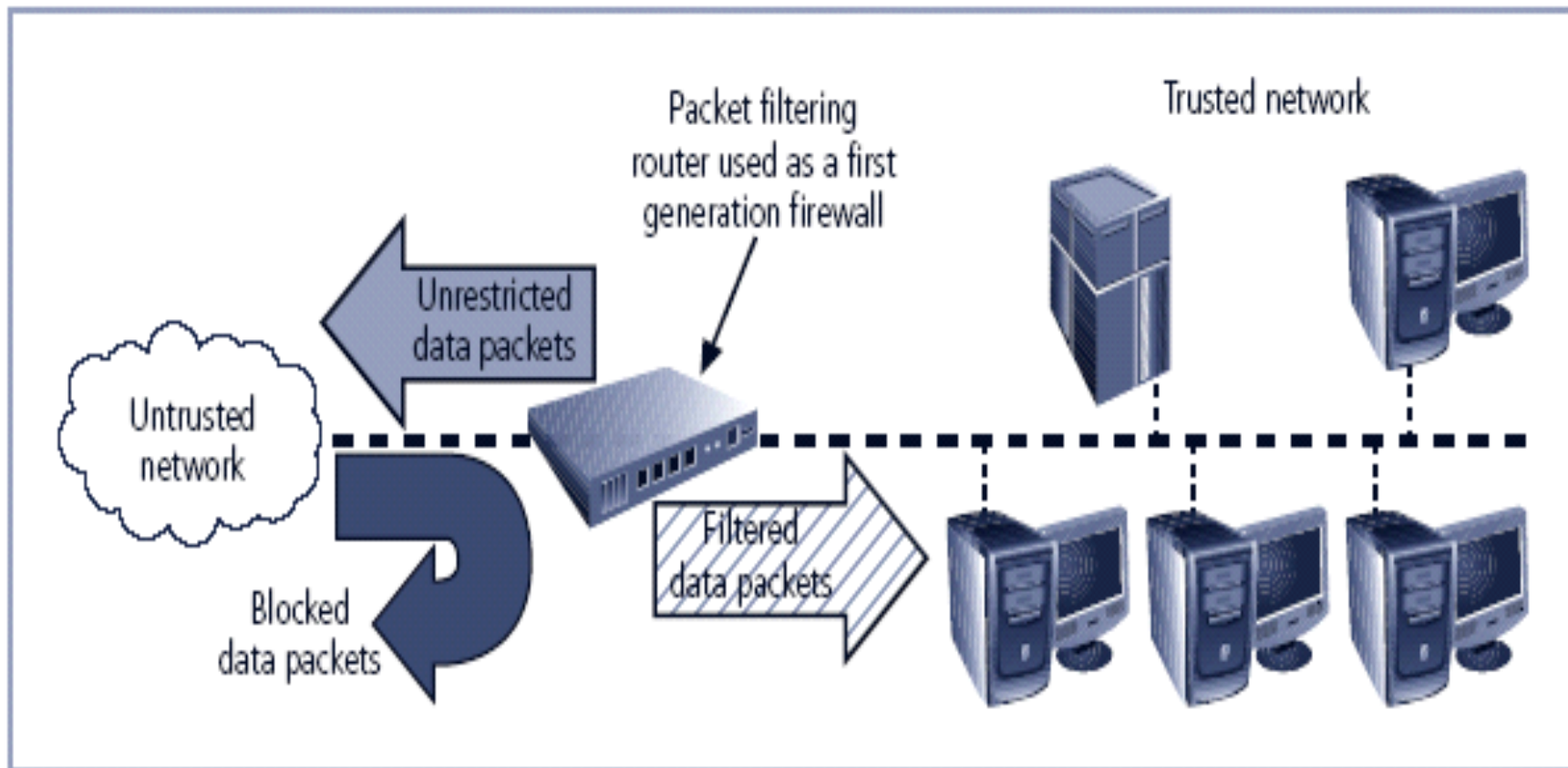


FIGURE 6-4 Packet Filtering Router

So How Do Authorized People Get Through the Perimeter?

01

No organisation is an island

Organisations cannot exist as islands. In order for organisations to be productive, authorised information must have safe passage inside and out, so the system of boundaries must have a system of gates.

02

The VPN is the gate

A virtual private network, or VPN, allows a remote user to bypass the logical perimeter of the organisation and interact with the interior zones as if they were present there.

Crossing the Boundary: The VPN

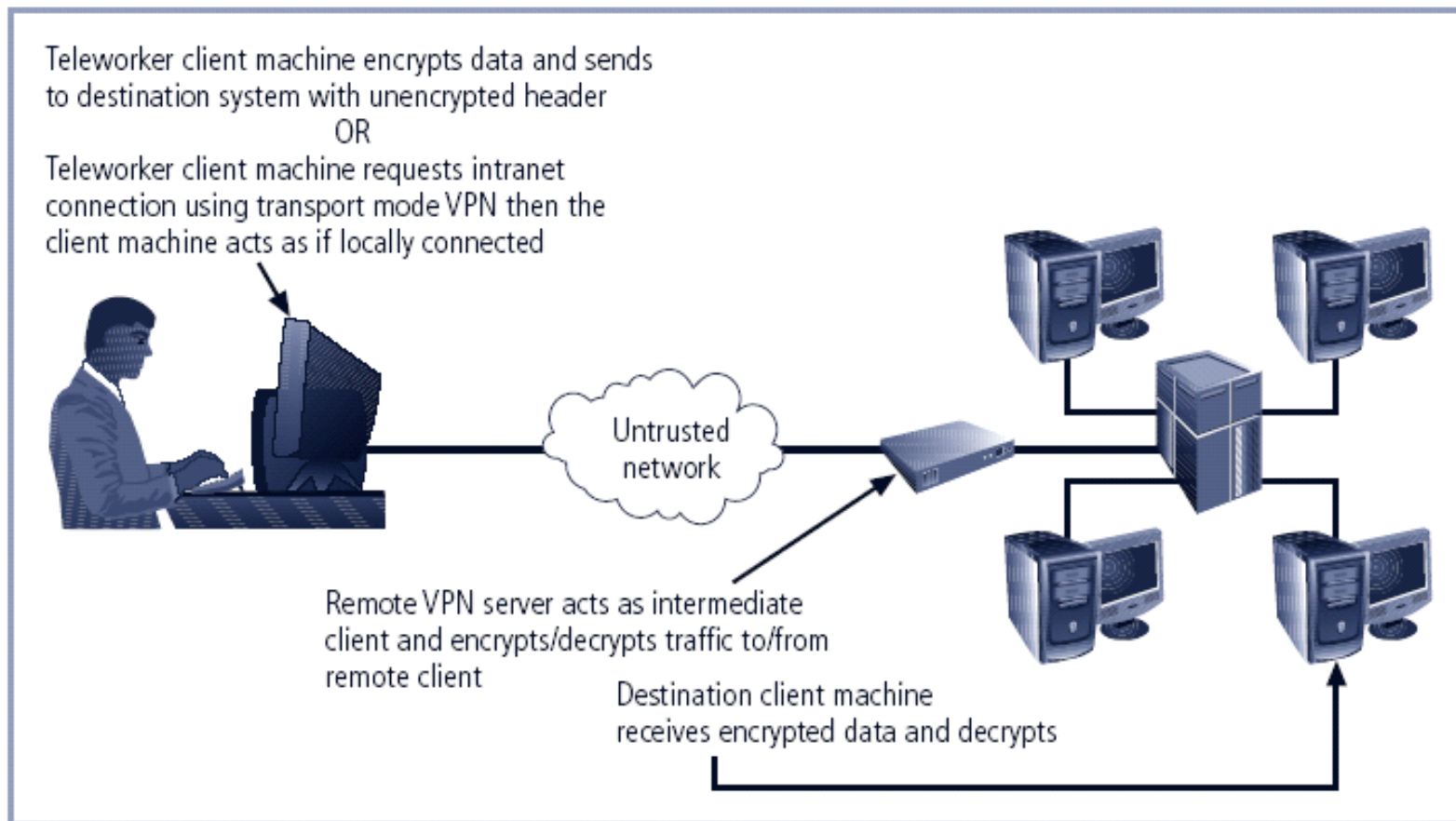


FIGURE 6-18 Transport Mode VPN

Second Line of Defence: Observe

Intrusion detection — network sensors and host agents.

Intrusion detection systems (IDS) are computer programs that constitute a second line of defence.

Surveil

IDS are like police detectives roaming around the network, they ‘watch’ the network looking for suspicious behaviour (e.g. network probes) that might constitute a threat.

Alert

They then alert the relevant authority for them to take action.

Vantage Points

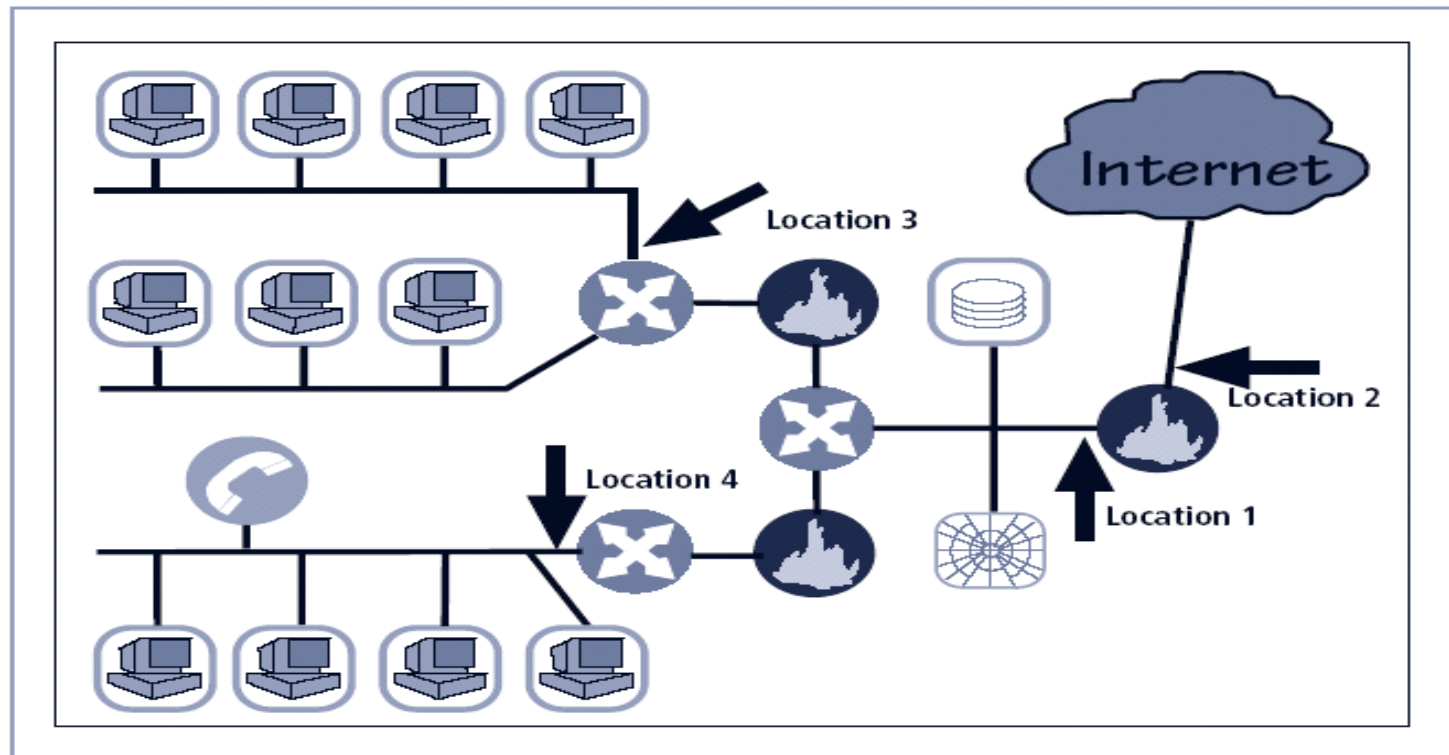


FIGURE 7-7 Network IDS Sensor Locations¹⁷

Third Line of Defence: Mediate

Identity, access control and encryption.

01

Authenticate

Authenticate individuals.

02

Authorise

Decide what these individuals can and cannot do.

03

Control access

Control what resources the individuals can access.

04

Encrypt

Impose a layer of protection around information assets using encryption.

Knowing Your Own Attack Surface

You cannot defend ground you have not surveyed — and the ground changes every week, without anyone deciding that it should.

01

What is exposed

Which systems, services and ports can be reached from outside, and by whom. Port scanners; operating system detection tools.

02

What is misconfigured

Where the controls you already own have drifted out of their intended state. Firewall analysers; vulnerability scanners.

03

What is leaking

What is visible to anyone listening, on the wire and over the air. Sniffers; wireless security tools.

THE CLOUD PROBLEM

Ownership Without Possession

You own the assets. Someone else holds them. How much of the castle you can build depends on the service model.

MORE CONTROL · MORE OBLIGATION

Infrastructure as a service

The land is given. You build the castle — walls, gates, guards, and the rooms the assets sit in.



Platform as a service

Land and building are given. You furnish it: mechanisms inside, and the protocols by which assets are reached.



Software as a service

Land, building and furnishings are given. You define only who may enter which room, and on what terms.

LESS CONTROL · MORE RELIANCE

Ownership and accountability stay with you in all three. Only the share of the castle you build yourself changes.

Protection That Travels With the Data

You stop controlling the infrastructure the data sits on, and start controlling the envelope around the data itself.

01

Encryption is the envelope

The data is encrypted with keys the organisation holds, not the provider's. Whoever reaches the storage reaches ciphertext.

02

The policy travels with it

Each asset carries its own classification and access rules, so the rules apply wherever the asset ends up.

03

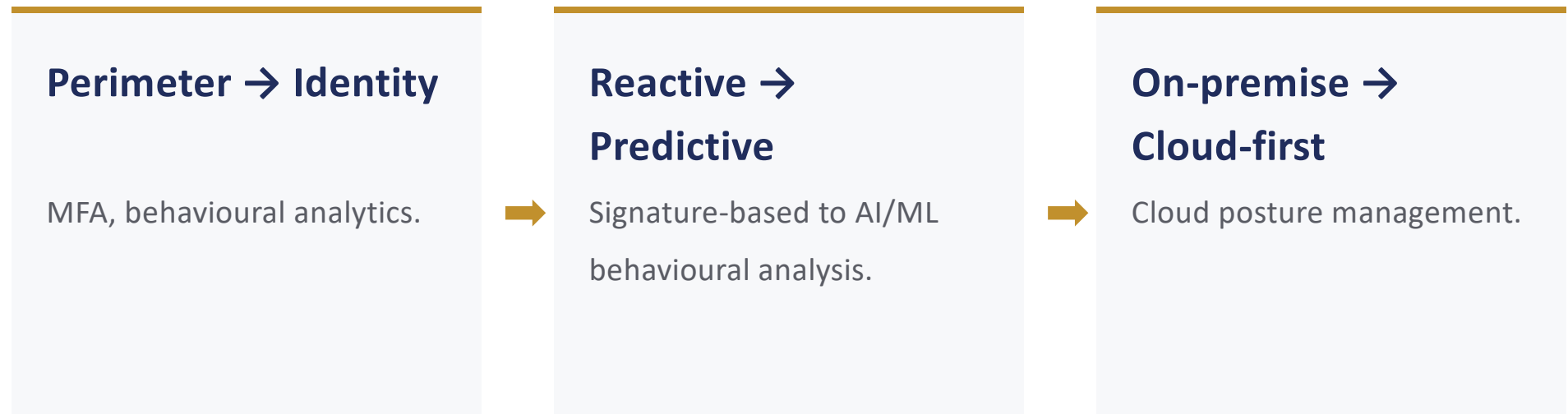
Identity does the enforcing

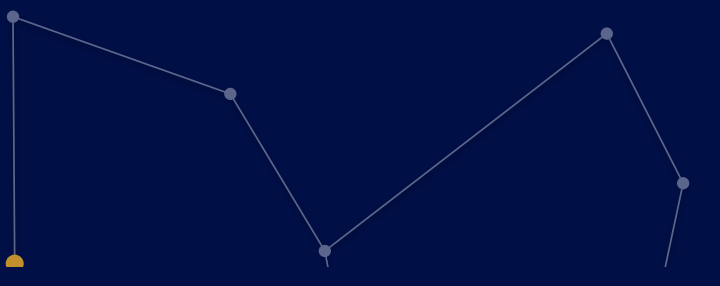
Access is decided per request against who is asking, in what role, from where — not against which network they happen to sit on.

WHERE THIS IS GOING

Key Technology Transformations

The foundational concepts remain important, but the implementation has been revolutionized by cloud computing, artificial intelligence, and distributed workforces.





Q&A

Defence in depth — and the technologies in each layer.

